

MASTER'S THESIS

Thesis submitted in fulfillment of the requirements for the degree of Master of Science in Engineering at the University of Applied Sciences Technikum Wien - Degree Program Information Systems Management

Retrieval-Augmented Generation for Cyber Threat Intelligence: Designing and Evaluating a Prototype to Support Security Analysts

By: Joben Preet Bhinder, BSc.

Student Number: 2410302067

Supervisors: Wolfgang Rogner, BSc. MSc.

Tamás Horváth, BSc. MSc.

Vienna, July 18, 2026

Declaration

“As author and creator of this work to hand, I confirm with my signature knowledge of the relevant copyright regulations governed by higher education acts (see Urheberrechtsgesetz /Austrian copyright law as amended as well as the Statute on Studies Act Provisions / Examination Regulations of the UAS Technikum Wien as amended).

I hereby declare that I completed the present work independently and that any ideas, whether written by others or by myself, have been fully sourced and referenced. I am aware of any consequences I may face on the part of the degree program director if there should be evidence of missing autonomy and independence or evidence of any intent to fraudulently achieve a pass mark for this work (see Statute on Studies Act Provisions / Examination Regulations of the UAS Technikum Wien as amended).

I further declare that up to this date I have not published the work to hand nor have I presented it to another examination board in the same or similar form. I affirm that the version submitted matches the version in the upload tool.“

Vienna, July 18, 2026

Digital Signature

Kurzfassung

Schlagworte: RAG, Cyber Threat Intelligence, Retrieval-Augmented Generation, Evaluation

Abstract

Keywords: RAG, Cyber Threat Intelligence, Retrieval-Augmented Generation, Evaluation

Acknowledgements

Contents

1	Introduction	1
1.1	Motivation and problem statement	1
1.2	Solution approach	1
1.3	Research questions	2
1.4	Objectives, scope and delimitation	3
1.5	Methodological approach	3
2	Background and Related Work	3
2.1	CTI and RAG foundations	4
2.2	Key findings from the literature	5
2.3	Research gaps	6
3	Solution: Design and Implementation	7
3.1	Task formulation	7
3.2	Requirements and design criteria	8
3.3	System architecture	8
3.4	Data ingestion and preprocessing	8
3.5	Hybrid retrieval and reranking	8
3.6	Context assembly, answer generation and citation	8
3.7	Implementation	9
3.8	Evaluation design	9
3.8.1	Test set construction	9
3.8.2	RAGAS metrics	9
3.8.3	Baseline and variant configurations	9
3.8.4	Experimental protocol	9
4	Results and Critical Appraisal	9
4.1	Experimental setup	9
4.2	Retrieval performance	9
4.3	Generation quality	10
4.4	Baseline comparison and ablation	10
4.5	Scenario-based evaluation of representative outputs	10
4.5.1	Vulnerability assessment	10
4.5.2	IOC enrichment	10

4.5.3 Threat actor context building	10
4.6 Assessment against the design criteria	10
4.7 Reference model for CTI-RAG integration	10
4.8 Answering the research questions	11
5 Conclusion, Limitations and Outlook	11
5.1 Summary and contributions	11
5.2 Limitations	12
5.3 Future work	12
Bibliography	13
List of Figures	15
List of Tables	16
Documentation table of AI-based tools	17
List of Abbreviations	18
A Additional Evaluation Tables	19
B Prompt Templates	20

1 Introduction

1.1 Motivation and problem statement

Cyber Threat Intelligence (CTI) turns raw threat data into assessments that security teams can act on. The underlying data is heterogeneous: structured feeds such as CVE/NVD and MISP coexist with unstructured advisories, vendor reports, and security blogs (Sun et al. 2023). In threat hunting, analysts correlate new indicators and attacker techniques across these sources under time pressure, while the volume and change rate of threat information keep growing (Rajapaksha, Rani, and Karafili 2024). A substantial share of analyst time is therefore spent reading and cross-referencing sources rather than investigating.

Large Language Models (LLMs) can summarize and extract information from such material and are increasingly applied in security operations (Divakaran and Peddinti 2024). Three limitations restrict their direct use in CTI. First, their parametric knowledge is static; a deployed model misses vulnerabilities disclosed after training (Gao et al. 2024). Second, LLMs hallucinate: they produce fluent statements that no source supports (Gao et al. 2024). Third, their output carries no provenance, so analysts must verify each claim manually before acting on it (Rajapaksha, Rani, and Karafili 2024).

Retrieval-Augmented Generation (RAG) mitigates these limitations by retrieving evidence from an external, continuously updatable knowledge store at query time and conditioning generation on the retrieved context (Lewis et al. 2020). In the CTI domain, RAG has been applied to individual tasks such as TTP annotation and cyber-attack investigation (Fayyazi, Taghdimi, and Yang 2024; Rajapaksha, Rani, and Karafili 2024). Empirical evidence on how RAG performs across analyst workflows, and which architectural choices drive that performance, remains limited (Gao et al. 2024). This thesis addresses that gap with a working prototype and its empirical evaluation.

1.2 Solution approach

This thesis designs, implements, and evaluates a RAG prototype for CTI analyst support. The prototype ingests representative CTI sources, including CVE/NVD entries, CISA advisories, MISP events, and vendor reports, into a unified index. A hybrid retrieval layer combines lexical

search (BM25) with dense vector search and reranks the merged candidates. A locally deployed open-source LLM generates the answer from the retrieved context. Each answer cites the sources it draws on, so analysts can verify individual claims instead of trusting the output as a whole.

The evaluation measures retrieval quality with information-retrieval metrics and answer quality with the RAGAS framework (Es et al. 2023). Retrieval variants are compared against each other and against a non-retrieval baseline on a fixed query set covering three representative analyst tasks: vulnerability assessment, IOC enrichment, and threat actor context building. The empirical findings are consolidated into a reference model for integrating RAG into CTI and threat-hunting workflows.

1.3 Research questions

From this problem context, one main research question and three sub-questions guide the thesis. Section 4.8 answers them on the basis of the evaluation results.

Main research question (MRQ)

How can a Retrieval-Augmented Generation (RAG) system leveraging Large Language Models improve the quality, reliability, and operational usefulness of Cyber Threat Intelligence (CTI) analysis and Threat-Hunting workflows?

SRQ1 — Information retrieval and answer quality

To what extent does retrieval augmentation improve the completeness, factual accuracy, and recency of CTI information generated by an LLM compared to a non-retrieval baseline?

SRQ2 — Practical utility and workflow support

Which types of CTI analysis tasks can be effectively supported by a RAG-based LLM system, and how well do the generated outputs align with the informational needs of threat-hunting workflows?

SRQ3 — Conceptual design

How can empirical insights from the RAG-LLM prototype be translated into actionable design principles for integrating generative AI into CTI and threat-hunting workflows?

1.4 Objectives, scope and delimitation

The objective of this thesis is a functional, empirically evaluated RAG prototype for CTI analyst support, together with a reference model that generalizes the evaluation results. The target group comprises security analysts and threat hunters; security managers who oversee the adoption of AI-assisted tooling in Security Operations Centers (SOCs) are a secondary audience.

Four delimitations bound the scope. First, the thesis does not pursue large-scale data collection; a curated set of representative sources serves as input, because the research focus lies on retrieval and reasoning quality rather than source coverage. Second, the prototype uses open-source components only. Third, the agent-based extension via the Model Context Protocol (MCP) is exploratory and not part of the core evaluation. Fourth, the evaluation combines quantitative metrics with scenario-based analysis; a user study with practicing analysts is out of scope.

1.5 Methodological approach

The thesis proceeds in six phases:

1. **Literature review:** analysis of LLM use in security operations, RAG architectures, and evaluation methods; the resulting findings and gaps are summarized in Chapter 2.
2. **Process analysis:** definition of representative CTI tasks and derivation of the evaluation query set (Section 3.8.1).
3. **Prototype development:** implementation of ingestion, hybrid retrieval, and grounded answer generation (Chapter 3).
4. **Quantitative evaluation:** information-retrieval metrics and RAGAS scores across retrieval variants and a non-retrieval baseline, including an ablation study.
5. **Qualitative evaluation:** scenario-based analysis of system outputs for the defined CTI tasks.
6. **Reference modeling:** consolidation of the empirical findings into an integration model for CTI workflows (Section 4.7).

2 Background and Related Work

2.1 CTI and RAG foundations

Cyber Threat Intelligence (CTI) is evidence-based knowledge about existing or emerging threats, including context, indicators, and actionable advice that informs security decisions (Sun et al. 2023). In practice, CTI is communicated through recurring artifact types. Indicators of Compromise (IOCs) are forensic artifacts, such as file hashes, IP addresses, or domains, that indicate a compromised system (Palacín 2021). Tactics, Techniques, and Procedures (TTPs) describe adversary behavior on three levels: the tactical goal, the method used to achieve it, and its concrete implementation (Ismail et al. 2025). The MITRE ATT&CK framework is the industry standard for categorizing these behaviors (Lekssays et al. 2025). Threat hunting builds on CTI: analysts proactively and iteratively search their environment for signs of compromise that automated detection has missed, typically starting from intelligence about the adversary (Palacín 2021; Sun et al. 2023).

Analyst workflows follow a recurring cycle from planning and collection through processing and analysis to dissemination (Palacín 2021). Across this cycle, the literature reports three bottlenecks:

1. **B1 — Information overload:** the volume, heterogeneity, and informal structure of threat feeds and reports exceed what analysts can process consistently (Alhuzali 2025; Rastogi and Alam 2023).
2. **B2 — Recency:** threat knowledge changes faster than static knowledge bases, including the parametric knowledge of trained language models, can follow (Paul et al. 2025; Chen et al. 2023).
3. **B3 — Verification effort:** extracting information from unstructured reports and validating it remains manual expert work, and outputs without transparent provenance cannot be acted on (Rajapaksha, Rani, and Karafili 2024; Tseng et al. 2024).

Retrieval-Augmented Generation (RAG) grounds LLM output in external knowledge. A RAG pipeline indexes documents by cleaning, chunking, and embedding them, retrieves the passages most relevant to a query, optionally reranks them, and assembles them into the prompt from which the model generates its answer (Gao et al. 2024). This design targets the LLM limitations most relevant to CTI: hallucination, outdated knowledge, and reasoning that cannot be traced to sources (Gao et al. 2024; Chen et al. 2023).

Retrieval can be sparse, dense, or hybrid; Table 1 contrasts the strategies and the role of reranking (Agnihotram and Sarkar 2025).

Strategy	Principle	Strength	Limitation
Sparse (BM25)	exact term matching with term-frequency weighting	efficient; reliable for explicit identifiers	misses semantically equivalent formulations
Dense	embeddings in a shared vector space	captures paraphrases and related concepts	can surface related yet irrelevant passages
Hybrid	parallel sparse and dense retrieval, merged by rank or score fusion	keeps exact matches while adding semantic coverage	merged list still needs re-ordering
Reranking	cross-encoder scores each query–passage pair	raises precision with little recall loss	adds latency

Table 1: Retrieval strategies and reranking in RAG pipelines

These trade-offs matter for CTI text, where the same threat actor appears under aliases such as APT28 and Fancy Bear and distinct ATT&CK techniques share overlapping keywords; hybrid retrieval with reranking therefore suits CTI corpora (Alhuzali 2025; Lekssays et al. 2025). Citing the retrieved sources in the generated answer makes it verifiable: analysts can inspect the evidence behind each claim instead of trusting the model (Rajapaksha, Rani, and Karafili 2024; Liu et al. 2023).

2.2 Key findings from the literature

The literature review covers four topic areas: CTI analyst workflows, LLMs in cybersecurity, RAG for CTI, and the evaluation of RAG systems. Table 2 summarizes the key findings; the research gaps in Section 2.3 follow from them.

Topic area	Key finding	Source
CTI analyst workflows	The volume and the non-uniform, informal structure of threat feeds overwhelm analysts; fully automated processing is not feasible	(Rastogi and Alam 2023; Alhuzali 2025)
	Analyzing natural-language CTI reports is labor-intensive and repetitive and delays response	(Tseng et al. 2024; Rajapaksha, Rani, and Karafili 2024)
LLMs in cybersecurity	LLMs support vulnerability analysis, report summarization, and IOC/TTP extraction; junior analysts gain the most	(Divakaran and Peddinti 2024)

continued on next page

Topic area	Key finding	Source
	Recurring failure modes are hallucination, outdated knowledge, and technical misinterpretation	(Alhuzali 2025)
	LLMs over-trust retrieved context and can be misled by incorrect information in it	(Chen et al. 2023)
RAG for CTI	Hybrid retrieval with reranking addresses terminology variance (actor aliases) and overlapping keywords in security text	(Alhuzali 2025; Lekssays et al. 2025)
	Retrieval grounding raises precision in TTP mapping, where decoder-only LLMs show high recall but low precision	(Fayyazi, Taghdimi, and Yang 2024)
	Existing CTI-RAG prototypes each target a single task, e.g. attack investigation, technique annotation, event response, or IOC extraction	(Alhuzali 2025; Lekssays et al. 2025; Ismail et al. 2025; Tseng et al. 2024)
RAG evaluation	Retrieval is assessed with Precision@k and Recall@k plus rank-aware metrics such as MRR and nDCG	(Agnihotram and Sarkar 2025; Yu et al. 2024)
	Reference-free frameworks (RAGAS, ARES) score faithfulness, answer relevancy, and context relevance without gold answers	(Es et al. 2023; Saad-Falcon et al. 2024)
	LLM-as-a-judge scoring risks reinforcing model biases and can diverge from human judgment in specialized domains	(Akkiraju et al. 2024; Yu et al. 2024)
	Industrial ground-truth datasets for CTI tasks are scarce; only few public benchmarks (e.g. CTIBench) exist	(Xu et al. 2025; Alhuzali 2025)

Table 2: Key findings of the literature review

2.3 Research gaps

From the findings in Table 2, three research gaps are derived:

1. **G1 — Workflow-level empirical evidence:** Existing CTI-RAG prototypes each address a single task, such as attack investigation or technique annotation. How RAG performs across the range of tasks an analyst works through, and which architectural choices drive that performance, remains empirically open.
2. **G2 — Evaluation realism:** Reported evaluations center on controlled benchmarks and

isolated technical metrics, and ground-truth datasets for CTI tasks are scarce. Evidence that connects retrieval and generation quality to representative analyst tasks is rare.

3. **G3 — Source reliability:** RAG pipelines can ingest and propagate misinformation, and LLMs tend to over-trust retrieved context. How CTI-RAG systems should account for the integrity and reliability of their sources is not settled.

These gaps, together with the workflow bottlenecks B1–B3 from Section 2.1, define the design space of this thesis: Section 3.2 derives design criteria from them, and Section 4.6 assesses the prototype against these criteria.

3 Solution: Design and Implementation

3.1 Task formulation

The task addressed in this thesis is grounded question answering over CTI sources. The prototype operates on a corpus $\mathcal{D}$ of documents collected from heterogeneous CTI sources and segmented into a set of passages $\mathcal{P}$ (Section 3.4). Given an analyst query q , a retrieval function R selects the k highest-ranked passages as context:

$$\mathcal{C}_k = R(q, \mathcal{P}), \quad |\mathcal{C}_k| = k. \quad (1)$$

A generation model g then produces the answer

$$a = g(q, \mathcal{C}_k), \quad (2)$$

subject to a grounding constraint: every factual claim in a must be attributable to at least one passage in $\mathcal{C}_k$ and marked with an inline citation to that passage. The analyst can therefore verify each claim against its source instead of trusting the answer as a whole (bottleneck B3, Section 2.1).

In the hybrid configuration, R combines a lexical relevance score (BM25) with a semantic similarity score (dense embeddings) and reranks the fused candidates; Section 3.5 describes this instantiation. Setting $\mathcal{C}_k = \emptyset$ yields the non-retrieval baseline

$$a_0 = g(q, \emptyset), \quad (3)$$

in which the model answers from parametric knowledge alone. This baseline corresponds to configuration V0 in the evaluation (Section 3.8.3); the comparison between a and a_0 quantifies the effect of retrieval augmentation and thereby operationalizes SRQ1.

3.2 Requirements and design criteria

ID	Design criterion	Gap	Ref.
C1	Evidence-linked outputs: explicit, source-based citations for key claims to support traceability and reduce verification effort	G1	SRQ1
C2	Hybrid retrieval as a baseline: combined lexical (BM25) and semantic retrieval with optional reranking	G1	SRQ1
C3	Source integrity and reliability: curated ingestion and source-reliability signals to limit misinformation risk	G3	MRQ
C4	Scenario-based evaluation: assessment on representative CTI analyst tasks beyond offline metrics	G2	SRQ2
C5	Analyst-oriented presentation: structured outputs matching analyst intent (task coverage, clarity, transparency)	G2	SRQ2
C6	Open-source, locally deployable stack (data protection, reproducibility, cost)	—	MRQ

Table 3: Design criteria with traceability to research gaps and research questions

3.3 System architecture

...

3.4 Data ingestion and preprocessing

...

3.5 Hybrid retrieval and reranking

...

3.6 Context assembly, answer generation and citation

...

3.7 Implementation

...

3.8 Evaluation design

3.8.1 Test set construction

...

3.8.2 RAGAS metrics

...

3.8.3 Baseline and variant configurations

...

3.8.4 Experimental protocol

...

4 Results and Critical Appraisal

4.1 Experimental setup

...

4.2 Retrieval performance

...

4.3 Generation quality

...

4.4 Baseline comparison and ablation

...

4.5 Scenario-based evaluation of representative outputs

4.5.1 Vulnerability assessment

...

4.5.2 IOC enrichment

...

4.5.3 Threat actor context building

...

4.6 Assessment against the design criteria

...

4.7 Reference model for CTI-RAG integration

...

4.8 Answering the research questions

MRQ

Answer: ...

Evidence:

- ... (Section 4.2)
- ... (Section 4.3)
- ... (Section 4.6)

SRQ1 — Information retrieval and answer quality

Answer: ...

Evidence:

- ... (Section 4.2, Section 4.4)

SRQ2 — Practical utility and workflow support

Answer: ...

Evidence:

- Vulnerability assessment: ... (Section 4.5.1)
- IOC enrichment: ... (Section 4.5.2)
- Threat actor context: ... (Section 4.5.3)

SRQ3 — Conceptual design

Answer: ...

Evidence:

- ... (Section 4.7, Table 3)

5 Conclusion, Limitations and Outlook

5.1 Summary and contributions

...

5.2 Limitations

...

5.3 Future work

...

Bibliography

- Agnihotram, Gopichand and Joydeep Sarkar (2025). *Evaluating Precision and Recall at Retrieval Time in Retrieval-Augmented Generation (RAG) Systems*.
- Akkiraju, Rama et al. (2024). *FACTS About Building Retrieval Augmented Generation-based Chatbots*. arXiv preprint arXiv:2407.07858.
- Alhuzali, Abeer (2025). *LLM-Powered Threat Intelligence: A Retrieval-Augmented Generation Approach for Cyber Attack Investigation*.
- Chen, Jiawei et al. (2023). *Benchmarking Large Language Models in Retrieval-Augmented Generation*. arXiv preprint arXiv:2309.01431.
- Divakaran, Dinil Mon and Sai Teja Peddinti (2024). *LLMs for Cyber Security: New Opportunities*. arXiv preprint arXiv:2404.11338.
- Es, Shahul et al. (2023). *RAGAS: Automated Evaluation of Retrieval Augmented Generation*. arXiv preprint arXiv:2309.15217.
- Fayyazi, Reza, Rozhina Taghdimi, and Shanchieh Jay Yang (2024). *Advancing TTP Analysis: Harnessing the Power of Large Language Models with Retrieval Augmented Generation*. arXiv preprint arXiv:2401.00280.
- Gao, Yunfan et al. (2024). *Retrieval-Augmented Generation for Large Language Models: A Survey*. arXiv preprint arXiv:2312.10997.
- Ismail, Muhammad et al. (2025). *Enhancing Security Operations Center: Wazuh Security Event Response with Retrieval-Augmented-Generation-Driven Copilot*.
- Lekssays, Ahmed et al. (2025). *TechniqueRAG: Retrieval Augmented Generation for Adversarial Technique Annotation in Cyber Threat Intelligence Text*. arXiv preprint arXiv:2505.11988.
- Lewis, Patrick et al. (2020). "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks". In: *Advances in Neural Information Processing Systems*. Vol. 33, pp. 9459–9474.
- Liu, Yang et al. (2023). *Trustworthy LLMs: A Survey and Guideline for Evaluating Large Language Models' Alignment*. arXiv preprint arXiv:2308.05374.
- Palacín, Valentina (2021). *Practical Threat Intelligence and Data-Driven Threat Hunting*. Packt Publishing.
- Paul, Shuva et al. (2025). *LLM-Assisted Proactive Threat Intelligence for Automated Reasoning*.
- Rajapaksha, Sampath, Ruby Rani, and Erisa Karafili (2024). *A RAG-Based Question-Answering Solution for Cyber-Attack Investigation and Attribution*. arXiv preprint arXiv:2408.06272.
- Rastogi, Nidhi and Md Tanvirul Alam (2023). *Cyber Threat Intelligence for SOC Analysts*.

- Saad-Falcon, Jon et al. (2024). "ARES: An Automated Evaluation Framework for Retrieval-Augmented Generation Systems". In: *Proceedings of the 2024 Conference of the North American Chapter of the Association for Computational Linguistics (NAACL)*.
- Sun, Nan et al. (2023). "Cyber Threat Intelligence Mining for Proactive Cybersecurity Defense: A Survey and New Perspectives". In: *IEEE Communications Surveys & Tutorials* 25.3, pp. 1748–1774.
- Tseng, PeiYu et al. (2024). *Using LLMs to Automate Threat Intelligence Analysis Workflows in Security Operation Centers*.
- Xu, Hanxiang et al. (2025). *Large Language Models for Cyber Security: A Systematic Literature Review*. arXiv preprint arXiv:2405.04760.
- Yu, Hao et al. (2024). *Evaluation of Retrieval-Augmented Generation: A Survey*. arXiv preprint arXiv:2405.07437.

List of Figures

List of Tables

Table 1	Retrieval strategies and reranking in RAG pipelines	5
Table 2	Key findings of the literature review	6
Table 3	Design criteria with traceability to research gaps and research questions	8

Documentation table of AI-based tools

AI-Based Tool	Intended Use	Prompt, Source, Page, Paragraph. . .
DeepL Translate	Translation of an article in English	Source (XXX), Chapter X on page X-X
Chat GPT 4.0	Grammar and Spelling	"Please list issues with spelling and grammar in the following text: ...", Entire document

List of Abbreviations

AI	Artificial Intelligence
CTI	Cyber Threat Intelligence
LLM	Large Language Model
RAG	Retrieval-Augmented Generation
MCP	Model Context Protocol

A Additional Evaluation Tables

... Inhalt ...

B Prompt Templates

... Inhalt ...